ProofPath

Guia de implementacion y continuidad del proyecto

Sprints 1-7, staging en AWS, decisiones de seguridad, evidencia y plan de finalizacion

CONTEXTO LISTO

Preparada con evidencia del repositorio y el trabajo completado en este chat del proyecto.

Corte de auditoria: 21 de octubre de 2026

Repositorio: mausalinass/ProofPath

Commit vigente al iniciar este documento: ae6c64d

Nota de seguridad: se excluyeron intencionalmente API keys, access keys, claves privadas, identificadores de cuenta y valores secretos.

1. Resumen ejecutivo

Conclusion actual

ProofPath tiene implementado y guardado el alcance funcional de los Sprints 1-7. Se crearon un entorno seguro de staging en AWS y su pipeline de despliegue. El proyecto aun no esta terminado para produccion: staging reporta PostgreSQL no saludable, deben repetirse las auditorias de dependencias y la regresion completa, y faltan controles finales de privacidad y produccion.

Area	Resultado registrado
Implementacion	Sprints 1-7 implementados: identidad, perfil, inteligencia de resume, evidencia GitHub, empleos, matching, recomendaciones, tracking y herramientas de release.
Control de codigo	Trabajo guardado y enviado a GitHub. Los commits de sprints y correcciones de despliegue estan en main.
Nube	Cuenta AWS con MFA; almacenamiento privado, IAM, OIDC, ECR, ECS, RDS, CloudFront, Secrets Manager y CloudWatch declarados; staging desplegado.
Servicios externos	Creditos y API key de OpenAI configurados; GitHub App creada e instalada con lectura para el repositorio seleccionado.
Seguridad	La guia no incluye valores de credenciales. Las auditorias no encontraron secretos OpenAI/AWS/GitHub/PEM versionados.
Bloqueo inmediato	El frontend publico responde, pero /health/ready devolvio HTTP 503 porque PostgreSQL estaba no saludable el 2026-10-21.

Definicion de proyecto terminado

ProofPath v1 estara terminado cuando se completen las cinco sesiones, el rediseno del frontend, la validacion independiente, la aprobacion de produccion, el dominio, el despliegue y las comprobaciones posteriores. El mantenimiento normal continuara despues del lanzamiento.

2. Linea de tiempo y registro Git

Fecha	Commit	Hito
2026-09-01	83cd253	Repositorio inicializado.
2026-09-04	448bcf4	Base del proyecto y CI establecidos.
2026-09-30	769899a	Sprints 1-5 completados y guardados juntos.
2026-10-01	88fbffb	Sprints 6-7 completados con endurecimiento de produccion.
2026-10-01	6c4fda7	Pipeline seguro de staging agregado.
2026-10-01 a 2026-10-07	Varios	Correcciones de free plan, OIDC, ClamAV, dependencias, CloudFront y reintentos.
2026-10-07	fa7d28b	Ultima correccion registrada del despliegue: politica valida de cache CloudFront.
2026-10-21	ae6c64d	Checklist de finalizacion de ProofPath v1 agregado y enviado.

Regla documental

Los reportes historicos describen el estado al cerrar cada sprint. La fuente vigente para el trabajo pendiente es docs/Completion_Checklist.md. La auditoria mas reciente prevalece sobre textos antiguos como 'despliegue no ejecutado'.

Estado del repositorio al entregar

[HECHO] Main contenia los sprints completados y el trabajo de staging.

[HECHO] El checklist fue guardado y enviado como ae6c64d.

[HECHO] No quedaron cambios de fuente sin commit despues del push.

[HECHO] Este documento no reproduce credenciales ni valores secretos.

3. Alcance implementado - Sprints 1 y 2

Sprint 1 - Identidad, perfil y trabajos durables

[HECHO] Registro, login, logout y usuario actual mediante cookies.
[HECHO] Politica fuerte de contrasenas, bloqueo y rate limiting.
[HECHO] Proteccion CSRF en escrituras y origenes CORS explicitos.
[HECHO] Perfil limitado al propietario con identidad y timestamps controlados por el servidor.
[HECHO] Eliminacion privada de cuenta con confirmacion y contrasena.
[HECHO] Trabajos durables con estado, cancelacion, reintento y errores saneados.
[HECHO] Migracion CandidateProfile aplicada de forma aditiva sin reemplazar Identity.

Sprint 2 - Inteligencia de resume

[HECHO] Carga privada PDF/DOCX con validacion MIME, extension, firma y tamano.
[HECHO] Analisis de malware, parsing limitado y errores explicitos para documentos corruptos/no soportados.
[HECHO] Worker durable con leases, reintentos, cancelacion y cleanup.
[HECHO] OpenAI Responses con JSON Schema estricto, store=false, timeouts y validacion determinista.
[HECHO] Evidencia grounded con bloques fuente, citas y normalizacion controlada.
[HECHO] Revision del usuario, concurrencia optimista, confirmacion, version activa e historial inmutable.
[HECHO] S3 privado con acceso publico bloqueado, cifrado, keys opacas y borrado de versiones exactas.
[HECHO] Gates reales de OpenAI y S3 ejecutados solo con datos sinteticos.

Limite conocido

El archivo original no se envia a OpenAI. El texto extraido esta limitado y se redactan email y telefono reconocibles. Esto no es anonimizacion completa y store=false no garantiza por si solo Zero Data Retention.

4. Alcance implementado - Sprints 3 a 5

Sprint 3 - Evidencia de GitHub

[HECHO] Conexion GitHub App con state protegido, nonce de un uso y prevencion de replay.

[HECHO] Sin token OAuth persistente; tokens de instalacion breves y solo en memoria.

[HECHO] Metadata y Contents de solo lectura; repositorios seleccionados, maximo cinco.

[HECHO] Snapshot fijado a un SHA sin clonar el repositorio.

[HECHO] Deteccion determinista con ruta, SHA, fuerza y confianza.

[HECHO] Desconectar impide nuevo acceso y marca evidencia historica stale; borrado en cascada.

[HECHO] Gate real GitHub App completado sobre mausalinass/ProofPath con solo lectura.

Sprint 4 - Inteligencia de empleos

[HECHO] CRUD de empleos por propietario y analisis durable de descripciones.

[HECHO] Extraccion estructurada de requisitos tecnicos, experiencia, educacion, conductuales y contextuales.

[HECHO] Clasificacion required/preferred/unspecified, importancia y citas grounded.

[HECHO] Revision editable, RequirementSets confirmados inmutables e invalidacion por edicion.

[HECHO] Datos del candidato excluidos del request de descripcion laboral.

Sprint 5 - Motor de matching

[HECHO] Motor matching-v1 puro y determinista sin red, BD, AWS, GitHub ni LLM.

[HECHO] Pesos congelados, umbrales de cobertura y estados Missing, Uncertain y NotEvaluated.

[HECHO] Resultados inmutables, trazabilidad por requisito, snapshots e historial.

[HECHO] Evidencia conductual visible pero excluida del scoring.

[HECHO] UI integrada para score, componentes, evidencia, gaps, confianza y cobertura.

5. Alcance implementado - Sprints 6 y 7

Sprint 6 - Recomendaciones y seguimiento

[HECHO] Estados de candidatura desde Saved hasta Offer, Rejected y Withdrawn.
[HECHO] Notas privadas y proxima accion limitadas al propietario autenticado.
[HECHO] Recomendaciones deterministas ligadas a resultados inmutables.
[HECHO] Ciclo de recomendaciones: Open, InProgress, Completed y Dismissed.
[HECHO] El reanalisis crea nuevos snapshots de match y recomendaciones.
[HECHO] Comparacion historica con delta, cobertura, clasificacion y fecha.

Sprint 7 - Base para release de produccion

[HECHO] Contenedores no-root para frontend, API y Worker.
[HECHO] Templates CloudFormation para foundation, aplicacion y frontend.
[HECHO] CI GitHub Actions para backend, frontend, navegador, dependencias, templates y contenedores.
[HECHO] Despliegue GitHub OIDC sin claves AWS de larga duracion.
[HECHO] Imagenes ECR inmutables, migraciones controladas y staging protegido.
[HECHO] Endpoints de salud, logs seguros y trace IDs.
[HECHO] OpenTelemetry, logs CloudWatch y alarma base 5xx.
[HECHO] Claves Data Protection persistentes, Identity endurecido y registro productivo desactivado.
[HECHO] Verificacion CloudFront-origin con requests directos al ALB denegados.

Resultado funcional

La aplicacion soporta el flujo completo: perfil privado -> evidencia del resume -> evidencia GitHub seleccionada -> requisitos -> match explicable -> recomendaciones -> seguimiento e historial.

6. Cuentas externas e integraciones configuradas

OpenAI Platform

[HECHO] Se agregaron creditos API para desarrollo.
[HECHO] Se creo una API key restringida para escribir respuestas del modelo.
[HECHO] Una key mostrada antes en el chat se trato como expuesta y se reemplazo.
[HECHO] El valor activo quedo fuera de Git y luego se guardo en AWS Secrets Manager.
[HECHO] Staging esta aprobado solo para datos sinteticos; datos reales requieren otra aprobacion.

AWS

[HECHO] Cuenta AWS creada y MFA del root asignado.
[HECHO] El root no tiene access keys activas.
[HECHO] Bucket privado proofpath-dev-resumes creado en us-east-2.
[HECHO] Politica ProofPathLocalResumeStorage y usuario proofpath-local-worker creados.
[HECHO] Perfil AWS CLI proofpath-local configurado sin imprimir credenciales.
[HECHO] Foundation y secretos de aplicacion preparados para staging.

GitHub

[HECHO] GitHub App proofpath-development-mausalinass creada.
[HECHO] Private key generada y manejada fuera del repositorio.
[HECHO] Instalacion restringida al repositorio ProofPath.
[HECHO] Permisos limitados a Contents: read y Metadata: read.
[HECHO] El historial incluye commits de Sprints 1-5, Sprints 6-7 y correcciones de despliegue.

7. Arquitectura desplegada y limites de seguridad

Navegador del candidato	CloudFront	React web
HTTPS	Unico punto publico	Origen S3 privado
CloudFront VPC origin	**Internal ALB**	**ECS API + Worker**
Header de origen + red	Respuesta directa: 403	Tareas Fargate
RDS PostgreSQL privado	**S3 privado de resumes**	**Secrets Manager**
Durable product state	Encrypted and public-blocked	Credenciales runtime

Controles de seguridad implementados

Limite	Control implementado
Identidad	Cookies HttpOnly seguras, CSRF, CORS explicito, lockout, reglas de contrasena y limites.
Propiedad de datos	Cada operacion privada deriva el propietario de la sesion autenticada.
Documentos	S3 privado cifrado, gate de malware, limites, sin URLs publicas y cleanup durable.
GitHub	Permisos de lectura, seleccion explicita y tokens breves.
OpenAI	Schemas estrictos, validacion determinista, limites, redaccion y store=false.
Entrega	OIDC, imagenes inmutables, variables protegidas, Secrets Manager y gates.
Logging	Se permite metadata de trace/estado/duracion; se prohiben resumes, textos, passwords, cookies y keys.

8. Registro del despliegue staging en AWS

Autorizacion del propietario

El despliegue de staging fue autorizado expresamente, aceptando costos AWS y uso exclusivo de datos sinteticos. La creacion de CloudFormation y las reparaciones posteriores tambien fueron confirmadas.

[HECHO] Foundation creada en us-east-2 con red, RDS, storage, IAM, OIDC y ECR.

[HECHO] Secret de aplicacion creado en Secrets Manager sin exponer valores en Git.

[HECHO] Imagenes API y Worker construidas y enviadas como artefactos inmutables.

[HECHO] Frontend CloudFront desplegado con origen privado.

[HECHO] Pipeline reparado para OIDC, ClamAV, rol CloudFront, reintentos y cache.

[HECHO] URL publica registrada: https://d27i0fde08ymkz.cloudfront.net/

[HECHO] Workflow de despliegue completado para fa7d28b01c227282dc48af38b3aa4700a06ef0db.

Reglas del despliegue

- Solo documentos y empleos sinteticos estan aprobados en staging.
- El registro publico sigue desactivado hasta completar verificacion y recuperacion.
- Produccion requiere entorno, privacidad, roles y secretos separados.
- El callback GitHub debe coincidir con el hostname final.
- Los recursos pagos deben monitorearse y detenerse cuando no se necesiten.

9. Evidencia de validacion y auditoria actual

Evidencia registrada al cerrar los Sprints 1-7

Control	Evidencia historica aprobada
Backend	Hasta 89 tests aprobados; build con cero warnings y errores.
Frontend	12 tests, ESLint y build de produccion aprobados.
Navegador	Tres recorridos Playwright aprobados con PostgreSQL aislado.
Dependencias	NuGet y npm sin vulnerabilidades conocidas al cerrar Sprint 7.
Contenedores	API, Worker y web construidos como contenedores no-root.
Infraestructura	Templates CloudFormation aprobaron cfn-lint en CI.
Secretos	Sin patrones de keys OpenAI, AWS, GitHub o PEM en fuente/historial.

Auditoria realizada el 2026-10-21

Verificacion	Resultado actual
Git	Main local coincidia con origin/main; luego se guardo el checklist como ae6c64d.
URL frontend	HTTP 200.
URL login	HTTP 200.
API privada	Request sin autenticar devolvio HTTP 401.
Salud	HTTP 503; postgres no saludable.
Build backend	Build Release aprobo con 0 warnings y errores.
Tests backend	53 aprobaron; 36 no corrieron porque Docker/Testcontainers no alcanzo Docker Desktop.
Tests frontend	Lint, 12 tests y build productivo aprobados.
Auditoria dependencias	Aparecieron hallazgos altos en Vite y paquetes criptograficos .NET transitivos.

Interpretacion

Los sprints siguen validos como historial de implementacion, pero el release esta bloqueado hasta restaurar PostgreSQL, actualizar dependencias y repetir la regresion completa.

10. Trabajo pendiente antes de produccion

#	Frente	Requisito de finalizacion
1	Estabilidad	Reparar PostgreSQL y demostrar estabilidad de API y Worker.
2	Dependencias	Corregir hallazgos altos del frontend y .NET.
3	Regresion	Restaurar Docker y repetir backend, frontend y Playwright.
4	Flujo completo	Validar callback, upload, malware, extraccion, empleo, match y tracking con datos sinteticos.
5	Seguridad cloud	Agregar headers, reducir IAM y resolver subredes ECS/TLS interno.
6	Operaciones	Conectar alertas y cubrir RDS, ECS, readiness y costos.
7	Cuentas	Implementar verificacion de email y recuperacion/reset de contrasena.
8	Privacidad	Publicar aviso/consentimiento y aprobar retencion OpenAI o conseguir controles adecuados.
9	Resiliencia	Mejorar backups RDS, proteccion, disponibilidad y evidencia de restauracion.
10	Release	Redisenar frontend, auditoria final, dominio, produccion y controles posteriores.

Limite de produccion con OpenAI

Los datos de API no se usan para entrenamiento salvo opt-in. Los logs predeterminados de abuso pueden retener contenido hasta 30 dias. store=false no elimina por si solo esa retencion. Procesar resumes reales exige aceptacion expresa y aviso al usuario, o controles aprobados de Zero Data Retention / Modified Abuse Monitoring.

Referencia oficial: https://developers.openai.com/api/docs/guides/your-data

11. Plan de finalizacion en cinco sesiones

Sesion	Tema	Resultado requerido
1	Estabilizar staging	Diagnostico PostgreSQL/RDS/ECS/secrets/red, readiness 200, logs seguros y recuperacion.
2	Dependencias y tests	Actualizar paquetes, restaurar Docker, ejecutar suites y limpiar hallazgos altos.
3	Integraciones y E2E	Callback GitHub publico y flujo sintetico completo, incluido rechazo de malware.
4	Seguridad y DevOps	Headers, minimo privilegio, red/TLS, alarmas, presupuestos y retencion.
5	Preparacion productiva	Email/reset, privacidad, retencion, aislamiento, backup/restauracion y docs.

Regla de ejecucion

Cada sesion debe continuar por implementacion, validacion, documentacion, commit y push. Solo se pausa por login necesario, costo explicito o accion externa irreversible.

Despues de las cinco sesiones

[PENDIENTE] Redisenar el frontend y validar responsive y accesibilidad.

[PENDIENTE] Abrir chat dedicado de Testing, Security y DevOps para verificacion independiente.

[PENDIENTE] Ejecutar regresion, seguridad, restauracion y rollback en staging.

[PENDIENTE] Corregir bloqueos y crear candidato inmutable de produccion.

[PENDIENTE] Aprobar costos, privacidad, soporte y responsabilidad operativa.

[PENDIENTE] Configurar dominio, certificado ACM, DNS, callbacks y cookies seguras.

[PENDIENTE] Desplegar produccion y completar smoke, monitoreo y estabilidad.

12. Como debe continuar el siguiente chat

Abre el siguiente chat dentro del mismo proyecto ChatGPT y usa el repositorio como fuente de verdad. Debe leer AGENTS.md y docs/Completion_Checklist.md antes de cambiar archivos.

Primera instruccion recomendada

Continua ProofPath desde C:\Users\mausa\Projects\ProofPath. Lee AGENTS.md y docs/Completion_Checklist.md. Completa la Sesion 1 en una ejecucion continua. Conserva recursos y datos AWS. Ejecuta verificaciones, actualiza el checklist y haz commit/push cuando todo pase.

Reglas de control

[HECHO] Revisar Git status y confirmar el commit antes de editar.

[HECHO] No modificar el mirror de solo lectura bajo sources/.

[HECHO] No imprimir, capturar ni guardar valores secretos.

[HECHO] No destruir ni recrear AWS para simplificar el diagnostico.

[HECHO] Usar datos sinteticos hasta completar privacidad de datos reales.

[HECHO] Actualizar Completion_Checklist.md cuando las tareas se prueben.

[HECHO] Hacer commit y push solo despues de aprobar las validaciones.

Mensaje obligatorio de cierre

Sesiones 1-4: Terminamos la Sesion N. Seguiremos con la Sesion N+1.

Despues de la Sesion 5: Terminamos las cinco sesiones. ProofPath esta listo para el rediseno visual y la validacion final.

13. Referencias y entrega final

Proposito	Fuente del repositorio
Control vigente	docs/Completion_Checklist.md
Arquitectura	docs/Architecture.md
Evidencia de sprints	docs/Sprint_1_5B_Status.md and docs/Sprint_2_Status.md through docs/Sprint_7_Status.md
Modelo de seguridad	docs/Threat_Model.md
Decision OpenAI	docs/OpenAI_Privacy_Review.md
Procedimiento de despliegue	docs/Production_Runbook.md
Configuracion GitHub	docs/GitHub_Setup.md
CI	.github/workflows/ci.yml
Automatizacion	.github/workflows/deploy.yml
Infraestructura	infra/foundation.yml, infra/production.yml and infra/frontend.yml

Estado de la entrega

El historial, la nube, los limites de seguridad, el defecto actual y el orden de finalizacion quedan documentados. La siguiente accion es la Sesion 1: restaurar PostgreSQL sin destruir el trabajo existente.

Fin de la guia

Generada desde documentacion y Git verificados. Excluye valores de credenciales y no sustituye al checklist vivo.